

Narrativa explicativa del marco GQM + PRAGMATIC aplicado a STRIDE

El país quiere menos ciberdramas, los reguladores quieren menos sobresaltos en horario laboral y la organización quiere, en el fondo, saber dónde está poniendo el dinero. Entre esas tres pulsiones se sitúa el humilde indicador, esa cifra aparentemente fría que condensa decisiones, sistemas y, sobre todo, renunciadas.

El informe STRIDE nos dio seis formas canónicas de que todo se tuerza: suplantación, manipulación, negación, divulgación, saturación y golpes de Estado privilegiados. A partir de ahí, definir indicadores sin método sería como intentar medir la temperatura con una cinta métrica. Entra en escena GQM: Goal, Question, Metric.

GQM nos obliga a empezar por el principio correcto: **¿qué objetivo perseguimos?**. En este caso, los objetivos nacionales y organizativos están tintados por NIS2, el ENS y la realidad española: reducir incidentes de suplantación en servicios esenciales, evitar que alguien manipule un sistema eléctrico desde un portátil perdido, poder contar una historia coherente tras un incidente, mantener los datos sensibles fuera de manos y nubes indiscretas, garantizar que los servicios críticos aguantan el embate y que las cuentas privilegiadas no son llaves maestras en bolsillos desconocidos.

Una vez fijados los objetivos, formulamos preguntas de negocio y de seguridad: ¿hasta qué punto protegemos los accesos con MFA?, ¿qué porcentaje de dispositivos OT pueden ser actualizados con garantías?, ¿cada cuánto somos capaces de reconstruir un incidente?, ¿cuántos servicios esenciales han hecho un simulacro de caída este año? Solo entonces tiene sentido descender a las métricas: proporciones, porcentajes, tiempos, recuentos. Es decir, cosas medibles que no dependan de la inspiración del día.

Pero no todas las métricas nacen iguales. Algunas son decorativas, sirven para rellenar dashboards de colores; otras son activamente engañosas: dan una ilusión de control que no se corresponde con la realidad. Aquí entra PRAGMATIC, un acrónimo que recoge nueve criterios para distinguir las métricas que dicen algo del mundo de las que solo hablan de nuestro amor por las hojas de cálculo.

Una métrica es **Predictiva** si nos ayuda a anticipar problemas: el porcentaje de cuentas privilegiadas bajo PAM, por ejemplo, dice mucho sobre la probabilidad de que un incidente de escalada de privilegios se convierta en una catástrofe. Es **Relevante** si se conecta sin rodeos con los objetivos estratégicos y normativos: horas de indisponibilidad por servicio crítico es claramente relevante para cualquier consejo de administración y para cualquier transposición de NIS2 que se precie.

La métrica se vuelve **Accionable** cuando su variación sugiere qué hacer sin necesidad de interpretaciones esotéricas: un descenso en el porcentaje de servicios con protección DDoS lleva directamente a un plan de despliegue adicional; un aumento del tiempo medio para reconstruir incidentes apunta a invertir en logging, herramientas y procedimientos. Es **Genuina** cuando no se puede maquillar con facilidad: una cuenta privilegiada está o no está bajo PAM; los logs están o no están en soporte inmutable.

Significativa es aquella métrica que se puede explicar en una diapositiva sin perder al público: “el 40 % de nuestros servicios esenciales no han probado su plan de continuidad en los últimos dos años” suele captar la atención más que un índice compuesto sin traducción al mundo real. **Precisa** implica que la definición es clara, estable y no depende de interpretaciones subjetivas: qué consideramos “servicio crítico”, qué cuenta como “autenticación fuerte”, qué ventanas de tiempo usamos.

La **Oportunidad** habla de la frecuencia y velocidad con la que podemos obtener la métrica: horas de indisponibilidad anual tiene sentido con un cierto retraso, pero porcentaje de accesos con MFA puede revisarse más a menudo. La **Independencia** evita que midamos tres veces lo mismo con nombres distintos, y la **Rentabilidad** nos recuerda que hay métricas que cuestan más recolectar que lo que aportan en claridad o decisiones.

Cuando aplicamos GQM y PRAGMATIC a los indicadores del informe STRIDE, emergen algunos favoritos: el porcentaje de cuentas privilegiadas bajo PAM, la cobertura de MFA en accesos críticos, la proporción de sistemas con logs integrados en un SIEM, las horas de indisponibilidad por servicio esencial o la proporción de integraciones críticas con evaluación de riesgos completada. Todos ellos puntúan alto en relevancia, acción y significado, y razonablemente en coste, siempre que la organización tenga un mínimo de gobierno de activos y configuraciones.

Otros indicadores, como el porcentaje de dispositivos IoT con firmware firmado y arranque seguro, son extremadamente relevantes en ciertos sectores (OT, sanidad, industria) pero requieren esfuerzo considerable de inventario y verificación. Aquí, el criterio de rentabilidad invita a seleccionar bien dónde aplicar la lupa: quizá solo en los activos identificados ya como esenciales por la propia NIS2.

El resultado de este ejercicio no es un catálogo definitivo, sino una brújula: un marco que permite a un ministerio, a un regulador sectorial o a un CISO de empresa justificar por qué mide lo que mide, cómo esas métricas conectan con objetivos nacionales y qué grado de confianza puede depositarse en ellas. Si alguna métrica queda en evidencia —porque resulta poco predictiva, poco accionable o carísima de obtener—, el marco ofrece argumentos para retirarla o mejorarla, en lugar de perpetuarla por inercia.

Al final, GQM+PRAGMATIC aplicado a STRIDE es una forma elegante de responder a una pregunta aparentemente inocente: “¿Cómo sabemos que estamos mejorando?”. Si la respuesta se apoya en métricas bien alineadas, explicables y útiles, no garantizará la ausencia de incidentes, pero sí aumentará las probabilidades de que, cuando ocurran, no nos pillen ni ciegos ni mudos.